Protocolo de pruebas de pene-tracion

Spika Tech

TABLA DE CONTENIDO

1. Introducción y Propósito 4
2. Frecuencia y Programación de Pruebas 4
3. Requisitos Previos a las Pruebas 4
4. Procedimientos Principales de Prueba 4
4.1 Evaluación de Infraestructura Firebase Y Google 4
4.2 Pruebas de Seguridad de dispositivos MQTT 5
4.4 Pruebas del Sitio Web 5
4.5 Pruebas de Sistemas Internos 5
5. Estándares de Metodología de Pruebas 5
5.1 Marcos de Prueba Requeridos 5
5.2 Herramientas de Prueba Requeridas 5
6. Requisitos de Informes y Documentación 5
6.1 Secciones Estándar del Informe 5
6.3 Retención de Documentación 6
7. Proceso de Remediación 6
7.2 Pruebas de Verificación 6
8. Consideraciones Especiales 6
8.1 Protección de datos 6
8.2 Pruebas de Integración de Dispositivos Médicos 6
9. Mejora Continua 6
9.1 Revisión del Protocolo 6

9.2 Concienciación de Seguridad 7

10. Roles y Responsabilidades..... 7

10.1 Equipo de Seguridad Interno..... 7

10.2 Equipos de Desarrollo 7

10.3 Liderazgo Ejecutivo..... 7

1. Introducción y Propósito

Este documento establece el protocolo de pruebas de penetración para la infraestructura de sistemas de información de Spika Tech, diseñado para mantener el cumplimiento de la norma ISO 27001 y garantizar la seguridad continua de los datos y sistemas críticos. El protocolo establece un proceso consistente y repetible para identificar, evaluar y remediar vulnerabilidades de seguridad en toda la arquitectura tecnológica de Spika Tech.

2. Frecuencia y Programación de Pruebas

Componente del Sistema	Frecuencia de Pruebas	Consideraciones de Tiempo
Infraestructura Firebase y Google Cloud Run	Continua	Integración continua en CI/CD
Sistemas MQTT	Dependiente	Coordinar con mantenimiento de dispositivos MQTT
Sitios Web	Continua	Comprobaciones previas al despliegue
Sistemas Internos de Oficina	Anual	Programación en fines de semana o días festivos
Pruebas de penetración generalizadas a la infraestructura	Semestral	Dependiente de la prueba, en periodo de trabajo si implica un estudio del tráfico de datos del personal

3. Requisitos Previos a las Pruebas

- Notificación a personal clave que pueda verse afectado a través del canal de ciberseguridad de Teams.
- Autorización de dirección y del responsable de seguridad
- Obtención de permisos necesarios para las pruebas

4. Procedimientos Principales de Prueba

4.1 Evaluación de Infraestructura Firebase Y Google

- Validación de reglas de seguridad para todas las bases de datos Firebase
- Pruebas básicas de endpoints de API
- Controles de seguridad y autorización de funciones

contact@spikatech.com - www.spikatech.com

SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

- Escaneo con ScoutSuite de los endpoints expuestos
- Revisión de configuración de seguridad

4.2 Pruebas de Seguridad de dispositivos MQTT

- Verificación de seguridad en la capa de transporte

- Validación de autenticación y cifrado de datos de pacientes
- Escaneo de tráfico mediante Wazuh

4.4 Pruebas del Sitio Web

- Verificación de controles de autenticación
- Pruebas básicas de vulnerabilidades basadas en el OWASP TOP 10

- Validación de la gestión de sesiones

4.5 Pruebas de Sistemas Internos

- Evaluación de seguridad de correo electrónico
- Seguridad en el manejo de documentos
- Verificación de segregación de red
- Pruebas de control de acceso
- Cumplimiento de política de contraseñas
  Revisión de la configuración y eventos mediante Microsoft Entra

5. Estándares de Metodología de Pruebas

5.1 Marcos de Prueba Requeridos

- Guía de Pruebas OWASP para aplicaciones web
- Directrices de Cloud Security Alliance para Firebase y Google Cloud
- NIST SP 800-115 para procedimientos generales de prueba

5.2 Herramientas de Prueba Requeridas

- Seguridad web: OWASP ZAP(ZAProxy)
- Seguridad en la Nube: ScoutSuite
- Seguridad de Red: Nmap, openVAS
- Seguridad de Contenedores: Trivy
- Herramientas genéricas: Metasploit Framework

6. Requisitos de Informes y Documentación

6.1 Secciones Estándar del Informe

- Resumen Ejecutivo
- Alcance y Metodología
- Resumen de Hallazgos con Clasificaciones de Riesgo

contact@spikatech.com - www.spikatech.com
SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

- Hallazgos Técnicos Detallados
- Recomendaciones de Remediación
- Estado de Hallazgos Previos (para pruebas recurrentes)
- Mapeo de Controles ISO 27001

6.3 Retención de Documentación

- Todos los informes de pruebas deben conservarse según lo estipulado en el procedimiento de copias de seguridad.
- Las evidencias deben almacenarse en el repositorio de evidencias en Sharepoint
- Los planes de prueba y resultados deben ser accesibles para auditorías ISO 27001

7. Proceso de Remediación

7.2 Pruebas de Verificación

- Todos los hallazgos remediados deben someterse a pruebas de verificación
- Los resultados de verificación deben documentarse con evidencia
- Las actualizaciones de estado deben añadirse al sistema de gestión de vulnerabilidades

8. Consideraciones Especiales

8.1 Protección de datos

- Todas las actividades de prueba deben adherirse a las regulaciones de protección de datos RGPD y LOPDGDD
- Cualquier acceso inadvertido a datos debe reportarse inmediatamente
- Deben utilizarse datos de prueba siempre que sea posible

8.2 Pruebas de Integración de Dispositivos Médicos

- Las pruebas de dispositivos y sistemas no deben impactar las operaciones clínicas
- Las pruebas deben validar la transferencia segura de datos entre dispositivos y sistemas

9. Mejora Continua

9.1 Revisión del Protocolo

- Este protocolo debe revisarse anualmente
- Las actualizaciones deben incorporarse en base a:
  - Nuevas implementaciones tecnológicas
  - Cambios en el panorama de amenazas
  - Lecciones aprendidas de pruebas anteriores
  - Requisitos de cumplimiento actualizados

contact@spikatech.com - www.spikatech.com
SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.

9.2 Concienciación de Seguridad

- Los resultados de las pruebas (sanitizados) deben informar la capacitación en seguridad
- Las tendencias en los hallazgos deben analizarse para identificar necesidades de capacitación
- Los equipos de desarrollo deben recibir capacitación especializada basada en los hallazgos

10. Roles y Responsabilidades

10.1 Equipo de Seguridad Interno

- Coordinar el calendario de pruebas
- Gestionar proveedores de pruebas si se utilizan
- Revisar y validar hallazgos
- Seguir el progreso de remediación
- Informar resultados a la dirección

10.2 Equipos de Desarrollo

- Proporcionar documentación de arquitectura del sistema
- Asistir con el aprovisionamiento de cuentas de prueba
- Implementar medidas de remediación
- Participar en pruebas de verificación

10.3 Liderazgo Ejecutivo

- Autorizar actividades de pruebas de penetración
- Revisar el resumen ejecutivo de hallazgos
- Aprobar recursos para remediación
- Garantizar el cumplimiento del protocolo de pruebas

contact@spikatech.com - www.spikatech.com
SPIKA TECH, S.L., with registered office at c/ Alcalá de Guadaira, nº 6, 6ºA Derecha, 28018 MADRID, with Tax Identification Code B87386900, registered in the Mercantile Register of Madrid, in volume 33.500, Folio 200, Page M-603059, Entry. 1, hereinafter THE OWNER.